

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
1	Scope	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
2	Normative references	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
3	Terms and definitions	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
4	Overview	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
4.1	Structure of this document	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
4.2	Control layout	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
5	Organizational controls	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
5.1	Policies for information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Security, Compliance & Resilience Program (SCRP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
5.1	Policies for information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	8	
5.1	Policies for information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	
5.1	Policies for information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all forms of Personal Data (PD) are processed lawfully, fairly and transparently.	8	
5.1	Policies for information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Dissemination of Data Privacy Program Information	PRI-01.3	Mechanisms exist to: (1) Ensure that the public has access to information about organizational data privacy activities and can communicate with its Chief Privacy Officer (CPO) or similar role; (2) Ensure that organizational data privacy practices are publicly available through organizational websites or document repositories; (3) Utilize publicly facing email addresses and/or phone lines to enable the public to provide feedback and/or direct questions to data privacy office(s) regarding data privacy practices; and (4) Inform data subjects when changes are made to the privacy notice and the nature of such changes.	5	
5.1(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	8	
5.1(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	8	
5.1(b)	Other information for public cloud PII protection	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
5.1(b)	Other information for public cloud PII protection	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	8	
5.2	Information security roles and responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRP).	8	
5.2	Information security roles and responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	8	
5.2	Information security roles and responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization-defined personnel screening criteria.	3	
5.2	Information security roles and responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASC) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	8	
5.2	Information security roles and responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Personnel Security	TPM-06	Mechanisms exist to control personnel security requirements including security roles and responsibilities for third-party providers.	8	
5.2(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
5.3	Segregation of duties	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5	
5.3	Segregation of duties	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Incompatible Roles	HRS-12	Mechanisms exist to avoid incompatible development-specific roles through limiting and reviewing developer privileges to change hardware, software and firmware components within a production/operational environment.	5	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Security, Compliance & Resilience Program (SCRP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Commitment To Continual Improvements	GOV-01.3	Mechanisms exist to commit appropriate resources needed for continual improvement of the organization's Security, Compliance & Resilience Program (SCRP), including: (1) Staffing; (2) Budget; (3) Processes; and (4) Technologies.	5	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRP).	5	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Authoritative Chain of Command	GOV-04.2	Mechanisms exist to establish an authoritative chain of command with clear lines of communication to remove ambiguity from individuals and teams related to managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **ISO/IEC 27018:2025 - Information security, cybersecurity and privacy protection - Guidelines for protection of personally identifiable**

Focal Document URL: <https://www.iso.org/standard/27018>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-iso-27018-2025.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	5	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	8	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Resource Management	PRM-02	Mechanisms exist to address all capital planning and investment requests, including the resources needed to implement the Security, Compliance & Resilience Program (SCRPP) and document all exceptions to this requirement.	8	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all forms of Personal Data (PD) are processed lawfully, fairly and transparently.	8	
5.4	Management responsibilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Chief Privacy Officer (CPO)	PRI-01.1	Mechanisms exist to appoints a Chief Privacy Officer (CPO) or similar role, with the authority, mission, accountability and resources to coordinate, develop and implement, applicable data privacy requirements and manage data privacy risks through the organization-wide data privacy program.	8	
5.5	Contact with authorities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Contacts With Authorities	GOV-06	Mechanisms exist to identify and document appropriate contacts with relevant law enforcement and regulatory bodies.	10	
5.6	Contact with special interest groups	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Contacts With Groups & Associations	GOV-07	Mechanisms exist to establish contact with selected groups and associations within the security, compliance and resilience communities to: (1) Facilitate ongoing cybersecurity and data protection education and training for organizational personnel; (2) Maintain currency with recommended cybersecurity and data protection practices, techniques and technologies; and (3) Share current cybersecurity and/or data protection-related information including threats, vulnerabilities and incidents.	10	
5.7	Threat intelligence	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Monitoring For Information Disclosure	MON-11	Mechanisms exist to monitor for evidence of unauthorized exfiltration or disclosure of non-public information.	5	
5.7	Threat intelligence	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Monitoring for Indicators of Compromise (IOC)	MON-11.3	Automated mechanisms exist to identify and alert on Indicators of Compromise (IoC).	8	
5.7	Threat intelligence	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	10	
5.7	Threat intelligence	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Indicators of Exposure (IOE)	THR-02	Mechanisms exist to develop Indicators of Exposure (IOE) to understand the potential attack vectors that attackers could use to attack the organization.	8	
5.7	Threat intelligence	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	8	
5.7	Threat intelligence	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	10	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	8	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to protectively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and	8	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	8	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	5	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Risk Identification	RSK-03	Mechanisms exist to identify and document risks, both internal and external.	5	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	5	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related:	5	
5.8	Information security in project management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	5	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Asset-Service Dependencies	AST-01.1	Mechanisms exist to identify and assess the security of Technology Assets, Applications and/or Services (TAAS) that support more than one critical business function.	8	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Stakeholder Identification & Involvement	AST-01.2	Mechanisms exist to identify and involve pertinent stakeholders of critical Technology Assets, Applications, Services and/or Data (TAASD) to support the ongoing secure management of those assets.	5	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	8	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Action Mapping	AST-02.8	Mechanisms exist to create and maintain a map of Technology Assets, Applications and/or Services (TAAS) where sensitive and/or regulated data is stored, transmitted or processed.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **ISO/IEC 27018:2025 - Information security, cybersecurity and privacy protection - Guidelines for protection of personally identifiable**

Focal Document URL: <https://www.iso.org/standard/27018>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-iso-27018-2025.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Asset Ownership Assignment	AST-03	Mechanisms exist to ensure asset ownership responsibilities are assigned, tracked and managed at a team, individual, or responsible organization level to establish a common understanding of requirements for asset protection.	5	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Accountability Information	AST-03.1	Mechanisms exist to include capturing the name, position and/or role of individuals responsible/accountable for administering assets as part of the technology asset inventory process.	5	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Network Diagrams & Data Flow Diagrams (DFDs)	AST-04	Mechanisms exist to maintain network architecture diagrams that: (1) Contain sufficient detail to assess the security of the network's architecture; (2) Reflect the current architecture of the network environment; and (3) Document all sensitive and/or regulated data flows.	5	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Inventory of Personal Data (PD)	PRI-05.5	Mechanisms exist to establish and maintain a current inventory of all Technology Assets, Applications and/or Services (TAAS) that collect, receive, process, store, transmit, share, update and/or dispose Personal Data (PD).	5	
5.9	Inventory of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and	5	
5.10	Acceptable use of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	
5.10	Acceptable use of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	5	
5.10	Acceptable use of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Custodians	DCH-07.1	Mechanisms exist to identify custodians throughout the transport of digital or non-digital media.	5	
5.10	Acceptable use of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	8	
5.10	Acceptable use of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Social Media & Social Networking Restrictions	HRS-05.2	Mechanisms exist to define rules of behavior that contain explicit restrictions on the use of social media and networking sites, posting information on commercial websites and sharing account information.	8	
5.10	Acceptable use of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	8	
5.10	Acceptable use of information and other associated assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Access Agreements	HRS-06	Mechanisms exist to require internal and third-party users to sign appropriate access agreements prior to being granted access.	5	
5.11	Return of assets	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Return of Assets	AST-10	Mechanisms exist to ensure that employees and third-party users return all organizational assets in their possession upon termination of employment, contract or agreement.	10	
5.12	Classification of information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Governance	GOV-10	Mechanisms exist to facilitate data governance to oversee the organization's policies, standards and procedures so that sensitive and/or regulated data is effectively managed and maintained in accordance with applicable statutory, regulatory and contractual obligations.	8	
5.12	Classification of information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Asset Scope Classification	AST-04.1	Mechanisms exist to determine security, compliance and resilience control applicability by identifying, assigning and documenting the appropriate asset scope categorization for all Technology Assets, Applications and/or Services (TAAS) and personnel (internal and third-parties).	5	
5.12	Classification of information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	
5.12	Classification of information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	8	
5.13	Labelling of information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	8	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Transmission Confidentiality	CRY-03	Cryptographic mechanisms exist to protect the confidentiality of data being transmitted.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Custodians	DCH-07.1	Mechanisms exist to identify custodians throughout the transport of digital or non-digital media.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Information Sharing	DCH-14	Mechanisms exist to utilize a process to assist users in making information sharing decisions to ensure data is appropriately protected.	8	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Ad-Hoc Transfers	DCH-17	Mechanisms exist to secure ad-hoc exchanges of large digital files with internal or external parties.	8	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Access Agreements	HRS-06	Mechanisms exist to require internal and third-party users to sign appropriate access agreements prior to being granted access.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Flow Enforcement - Access Control Lists (ACLs)	NET-04	Mechanisms exist to implement and govern Access Control Lists (ACLs) to provide data flow enforcement that explicitly restrict network traffic to only what is authorized.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Deny Traffic by Default & Allow Traffic by Exception	NET-04.1	Mechanisms exist to configure firewall and router configurations to deny network traffic by default and allow network traffic by exception (e.g., deny all, permit by exception).	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	DNS & Content Filtering	NET-18	Mechanisms exist to force Internet-bound network traffic through a proxy device (e.g., Policy Enforcement Point (PEP)) for URL content filtering and DNS filtering to limit a user's ability to connect to dangerous or prohibited Internet sites.	5	
5.14	Information transfer	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	
5.14(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	8	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **ISO/IEC 27018:2025 - Information security, cybersecurity and privacy protection - Guidelines for protection of personally identifiable**

Focal Document URL: <https://www.iso.org/standard/27018>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-iso-27018-2025.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Identification & Authentication for Organizational Users	IAC-02	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) organizational users and processes acting on behalf of organizational users.	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	8	
5.15	Access control	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	8	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Identification & Authentication for Non-Organizational Users	IAC-03	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) third-party users and processes that provide services to the organization.	8	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Identification & Authentication for Devices	IAC-04	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) devices before establishing a connection using bidirectional authentication that is cryptographically-based and replay resistant.	8	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Identification & Authentication for Third-Party Technology Assets, Applications and/or Services (TAAS)	IAC-05	Mechanisms exist to identify and authenticate third-party Technology Assets, Applications and/or Services (TAAS).	8	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	8	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Identifier Management (User Names)	IAC-09	Mechanisms exist to govern naming standards for usernames and Technology Assets, Applications and/or Services (TAAS).	8	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	User Identity (ID) Management	IAC-09.1	Mechanisms exist to ensure proper user identification management for non-consumer users and administrators.	8	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Cross-Organization Management	IAC-09.4	Mechanisms exist to coordinate username identifiers with external organizations for cross-organization management of identifiers.	5	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	8	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Disable Inactive Accounts	IAC-15.3	Automated mechanisms exist to disable inactive accounts after an organization-defined time period.	5	
5.16	Identity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Restrictions on Shared Groups / Accounts	IAC-15.5	Mechanisms exist to authorize the use of shared/group accounts only under certain organization-defined conditions.	5	
5.16(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
5.16(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	8	
5.17	Authentication information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	8	
5.17	Authentication information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	8	
5.17	Authentication information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	8	
5.17	Authentication information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Default Authenticators	IAC-10.8	Mechanisms exist to ensure default authenticators are changed as part of account creation or system installation.	5	
5.17	Authentication information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	5	
5.17	Authentication information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	User Responsibilities for Account Management	IAC-18	Mechanisms exist to compel users to follow accepted practices in the use of authentication mechanisms (e.g., passwords, passphrases, physical or logical security tokens, smart cards, certificates, etc.).	8	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	8	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Termination of Employment	IAC-07.2	Mechanisms exist to revoke user access rights in a timely manner, upon termination of employment or contract.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Removal of Temporary / Emergency Accounts	IAC-15.2	Automated mechanisms exist to disable or remove temporary and emergency accounts after an organization-defined time period for each type of account.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: [ISO/IEC 27018:2025 - Information security, cybersecurity and privacy protection - Guidelines for protection of personally identifiable](#)

Focal Document URL: <https://www.iso.org/standard/27018>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-iso-27018-2025.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Privileged Account Inventories	IAI-16.1	Mechanisms exist to inventory all privileged accounts and validate that each person with elevated privileges is authorized by the appropriate level of organizational management.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Periodic Review of Account Privileges	IAI-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Credential Sharing	IAI-19	Mechanisms exist to prevent the sharing of generic IDs, passwords or other generic authentication methods.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Access Enforcement	IAI-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Access To Sensitive / Regulated Data	IAI-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Database Access	IAI-20.2	Mechanisms exist to restrict access to databases containing sensitive and/or regulated data to only necessary Technology Assets, Applications and/or Services (TAAS) or those individuals whose job requires such access.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Use of Privileged Utility Programs	IAI-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Least Privilege	IAI-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Management Approval For Privileged Accounts	IAI-21.3	Mechanisms exist to restrict the assignment of privileged accounts to management-approved personnel and/or roles.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	5	
5.18	Access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Inventories	TPM-01.1	Mechanisms exist to maintain a current, accurate and complete list of External Service Providers (ESPs) that can potentially impact the Confidentiality, Integrity, Availability and/or Safety (CIAS) of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Criticality Assessments	TPM-02	Mechanisms exist to identify, prioritize and assess suppliers and partners of critical Technology Assets, Applications and/or Services (TAAS) using a supply chain risk assessment process relative to their importance in supporting the delivery of high-value services.	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supply Chain Risk Management (SCRM)	TPM-03	Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS) supply chains; and (2) Take appropriate remediation actions to minimize the organization's exposure to those risks and threats, as necessary.	8	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Limit Potential Harm	TPM-03.2	Mechanisms exist to utilize security safeguards to limit harm from potential adversaries who identify and target the organization's supply chain.	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Processes To Address Weaknesses or Deficiencies	TPM-03.3	Mechanisms exist to address identified weaknesses or deficiencies in the security of the supply chain	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Conflict of Interests	TPM-04.3	Mechanisms exist to ensure that the interests of external service providers are consistent with and reflect organizational interests.	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	8	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Personnel Security	TPM-06	Mechanisms exist to control personnel security requirements including security roles and responsibilities for third-party providers.	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Deficiency Remediation	TPM-09	Mechanisms exist to address weaknesses or deficiencies in supply chain elements identified during independent or organizational assessments of such elements.	5	
5.19	Information security in supplier relationships	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Incident Response & Recovery Capabilities	TPM-11	Mechanisms exist to ensure response/recovery planning and testing are conducted with critical suppliers/providers.	5	
5.20	Addressing information security within supplier agreements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supply Chain Coordination	IRO-10.4	Mechanisms exist to provide cybersecurity and data protection incident information to the provider of the Technology Assets, Applications and/or Services (TAAS) and other organizations involved in the supply chain for TAAS related to the incident.	5	
5.20	Addressing information security within supplier agreements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
5.20	Addressing information security within supplier agreements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Limit Potential Harm	TPM-03.2	Mechanisms exist to utilize security safeguards to limit harm from potential adversaries who identify and target the organization's supply chain.	5	
5.20	Addressing information security within supplier agreements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	8	
5.20	Addressing information security within supplier agreements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	8	
5.20	Addressing information security within supplier agreements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology Assets, Applications, Services and/or Data (TAASD) that are in scope by the third-party.	8	
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Provenance	AST-03.2	Mechanisms exist to track the origin, development, ownership, location and changes to Technology Assets, Applications, Services and/or Data (TAASD).	5	
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	10	
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Specialized Assessments	IAO-02.2	Mechanisms exist to conduct specialized assessments for: (1) Statutory, regulatory and contractual compliance obligations; (2) Monitoring capabilities; (3) Mobile devices; (4) Databases; (5) Application security; (6) Embedded technologies (e.g., IoT, OT, etc.); (7) Vulnerability management; (8) Malicious code; (9) Insider threats; (10) Performance/load testing; (11) Artificial Intelligence and Autonomous Technologies (AAT); and/or (12) Other Technologies and Services (TAS).	8	
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	5	
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supply Chain Risk Management (SCRM)	TPM-03	Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS) supply chains; and (2) Take appropriate remediation actions to minimize the organization's exposure to those risks and threats, as necessary.	5	
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services (TAAS).	5	
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Processing, Storage and Service Locations	TPM-04.4	Mechanisms exist to restrict the location of information processing/storage based on business requirements.	5	
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
5.21	Managing information security in the ICT supply chain	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security Compromise Notification Agreements	TPM-05.1	Mechanisms exist to compel External Service Providers (ESPs) to provide notification of actual or potential compromises in the supply chain that can potentially affect or have adversely affected Technology Assets, Applications and/or Services (TAAS) that the organization utilizes.	5	
5.22	Monitoring, review and change management of supplier services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supply Chain Risk Management (SCRM)	TPM-03	Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS) supply chains; and (2) Take appropriate remediation actions to minimize the organization's exposure to those risks and threats, as necessary.	8	
5.22	Monitoring, review and change management of supplier services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services (TAAS).	5	
5.22	Monitoring, review and change management of supplier services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Processes To Address Weaknesses or Deficiencies	TPM-03.3	Mechanisms exist to address identified weaknesses or deficiencies in the security of the supply chain	5	
5.22	Monitoring, review and change management of supplier services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	8	
5.22	Monitoring, review and change management of supplier services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology Assets, Applications, Services and/or Data (TAASD) that are in scope by the third-party.	8	
5.23	Information security for use of cloud services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	10	
5.23	Information security for use of cloud services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Cloud Security Architecture	CLD-02	Mechanisms exist to ensure the cloud security architecture supports the organization's technology strategy to securely design, configure and maintain cloud employments.	8	
5.23	Information security for use of cloud services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Application Programming Interface (API) Security	CLD-04	Mechanisms exist to ensure support for secure interoperability between components with Application Programming Interfaces (APIs).	5	
5.23	Information security for use of cloud services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Multi-Tenant Environments	CLD-06	Mechanisms exist to ensure multi-tenant owned or managed assets (physical and virtual) are designed and governed such that provider and customer (tenant) user access is appropriately segmented from other tenant users.	8	
5.23	Information security for use of cloud services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Customer Responsibility Matrix (CRM)	CLD-06.1	Mechanisms exist to formally document a Customer Responsibility Matrix (CRM), delineating assigned responsibilities for security, compliance and resilience controls between the Cloud Service Provider and the customer.	8	
5.23	Information security for use of cloud services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Geolocation Requirements for Processing, Storage and Service Locations	CLD-09	Mechanisms exist to control the location of cloud processing/storage based on business requirements that includes statutory, regulatory and contractual obligations.	8	
5.23	Information security for use of cloud services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	
5.23	Information security for use of cloud services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Specialized Assessments	IAO-02.2	Mechanisms exist to conduct specialized assessments for: (1) Statutory, regulatory and contractual compliance obligations; (2) Monitoring capabilities; (3) Mobile devices; (4) Databases; (5) Application security; (6) Embedded technologies (e.g., IoT, OT, etc.); (7) Vulnerability management; (8) Malicious code; (9) Insider threats; (10) Performance/load testing; (11) Artificial Intelligence and Autonomous Technologies (AAT); and/or (12) Other Technologies and Services (TAS).	5	
5.23	Information security for use of cloud services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASC) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	8	
5.24	Information security incident management planning and preparation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	
5.24	Information security incident management planning and preparation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	8	
5.24	Information security incident management planning and preparation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	8	
5.24	Information security incident management planning and preparation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.25	Assessment and decision on information security events	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	
5.25	Assessment and decision on information security events	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Breach	IRO-04.1	Mechanisms exist to address data breaches, or other incidents involving the unauthorized disclosure of sensitive or regulated data, according to applicable laws, regulations and contractual obligations.	5	
5.25	Assessment and decision on information security events	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Integrated Security Incident Response Team (ISIRT)	IRO-07	Mechanisms exist to establish an integrated team of cybersecurity, IT and business function representatives that are capable of addressing cybersecurity and data protection incident response operations.	5	
5.25	Assessment and decision on information security events	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Situational Awareness For Incidents	IRO-09	Mechanisms exist to document, monitor and report the status of cybersecurity and data protection incidents to internal stakeholders all the way through the resolution of the incident.	5	
5.26	Response to information security incidents	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	
5.26	Response to information security incidents	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	8	
5.26	Response to information security incidents	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Integrated Security Incident Response Team (ISIRT)	IRO-07	Mechanisms exist to establish an integrated team of cybersecurity, IT and business function representatives that are capable of addressing cybersecurity and data protection incident response operations.	5	
5.26	Response to information security incidents	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	5	
5.26(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	10	
5.27	Learning from information security incidents	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	10	
5.28	Collection of evidence	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	
5.29	Information security during disruption	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
5.29	Information security during disruption	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Coordinate with Related Plans	BCD-01.1	Mechanisms exist to coordinate contingency plan development with internal and external elements responsible for related plans.	5	
5.29	Information security during disruption	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Coordinate With External Service Providers	BCD-01.2	Mechanisms exist to coordinate internal contingency plans with the contingency plans of external service providers to ensure that contingency requirements can be satisfied.	5	
5.29	Information security during disruption	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to execute the plan.	5	
5.29	Information security during disruption	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Incident Response Training	IRO-05	Mechanisms exist to train personnel in their incident response roles and responsibilities.	5	
5.29	Information security during disruption	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Coordination with Related Plans	IRO-06.1	Mechanisms exist to coordinate incident response testing with organizational elements responsible for related plans.	5	
5.29	Information security during disruption	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Coordination With External Providers	IRO-11.2	Mechanisms exist to establish a direct, cooperative relationship between the organization's incident response capability and external service providers.	5	
5.30	ICT readiness for business continuity	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	5	
5.30	ICT readiness for business continuity	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Asset-Service Dependencies	AST-01.1	Mechanisms exist to identify and assess the security of Technology Assets, Applications and/or Services (TAAS) that support more than one critical business function.	5	
5.30	ICT readiness for business continuity	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
5.30	ICT readiness for business continuity	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Coordinate with Related Plans	BCD-01.1	Mechanisms exist to coordinate contingency plan development with internal and external elements responsible for related plans.	5	
5.30	ICT readiness for business continuity	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Coordinate With External Service Providers	BCD-01.2	Mechanisms exist to coordinate internal contingency plans with the contingency plans of external service providers to ensure that contingency requirements can be satisfied.	5	
5.30	ICT readiness for business continuity	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to execute the plan.	5	
5.30	ICT readiness for business continuity	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
5.30	ICT readiness for business continuity	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Business Impact Analysis (BIA)	RSK-08	Mechanisms exist to conduct a Business Impact Analysis (BIA) to identify and assess security, compliance and resilience risks.	5	
5.31	Legal, statutory, regulatory and contractual requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	5	
5.31	Legal, statutory, regulatory and contractual requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
5.31	Legal, statutory, regulatory and contractual requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5	
5.31	Legal, statutory, regulatory and contractual requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Export-Controlled Cryptography	CRY-01.2	Mechanisms exist to address the exporting of cryptographic technologies in compliance with relevant statutory and regulatory requirements.	5	
5.31	Legal, statutory, regulatory and contractual requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
5.31	Legal, statutory, regulatory and contractual requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
5.32	Intellectual property rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	8	
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is provided, prior to collection, with: (1) Plain language explaining the potential data privacy risks of the authorization; (2) A means to decline the authorization; and (3) Necessary choice and consent-related criteria required by applicable statutory, regulatory and contractual obligations.	5	
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Restrict Collection, Processing & Sharing To Identified Purpose	PRI-04	Mechanisms exist to minimize the collection, processing and/or sharing of Personal Data (PD) to only what is adequate, relevant and limited to the purposes identified in the data privacy notice, including protections against collecting PD from minors without appropriate parental or legal guardian consent.	5	
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and (3) Use organization-defined techniques or methods to ensure secure deletion or destruction of PD (including originals, copies and archived records).	5	
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Internal Use of Personal Data (PD) For Testing, Training and Research	PRI-05.1	Mechanisms exist to address the use of Personal Data (PD) for internal testing, training and research that: (1) Takes measures to limit or minimize the amount of PD used for internal testing, training and research purposes; and (2) Authorizes the use of PD when such information is required for internal testing, training and research.	5	
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the implicit or explicit consent of the data subject.	5	
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
5.33	Protection of records	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	5	
5.34	Privacy and protection of PII	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all forms of Personal Data (PD) are processed lawfully, fairly and transparently.	10	
5.34	Privacy and protection of PII	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	8	
5.34	Privacy and protection of PII	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	8	
5.34	Privacy and protection of PII	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Purpose Specification	PRI-02.1	Mechanisms exist to ensure data privacy notices identify the purpose(s) for which Personal Data (PD) is collected, received, processed, stored, transmitted and/or shared.	8	
5.35	Independent review of information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Internal Audit Function	CPL-02.1	Mechanisms exist to implement an internal audit function that is capable of providing senior organization management with insights into the appropriateness of the organization's technology and information governance processes.	5	
5.35	Independent review of information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	
5.35	Independent review of information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	
5.35	Independent review of information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	
5.35	Independent review of information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Audit Activities	CPL-04	Mechanisms exist to thoughtfully plan audits by including input from operational risk and compliance partners to minimize the impact of audit-related activities on business operations.	5	
5.35(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	
5.35(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	5	
5.36	Compliance with policies, rules and standards for information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5	
5.36	Compliance with policies, rules and standards for information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	
5.36	Compliance with policies, rules and standards for information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	
5.36	Compliance with policies, rules and standards for information security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Personal Data (PD) Control Testing, Training & Monitoring	PRI-08	Mechanisms exist to conduct testing, training and monitoring activities for Personal Data (PD) controls.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **ISO/IEC 27018:2025 - Information security, cybersecurity and privacy protection - Guidelines for protection of personally identifiable**

Focal Document URL: <https://www.iso.org/standard/27018>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-iso-27018-2025.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.37	Documented operating procedures	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Program (SCRP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	5	
5.37	Documented operating procedures	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	8	
5.37	Documented operating procedures	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	
5.37	Documented operating procedures	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Operations Security	OPS-01	Mechanisms exist to facilitate the implementation of operational security controls.	5	
5.37	Documented operating procedures	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	8	
5.37	Documented operating procedures	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	5	
6	People controls	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
6.1	Screening	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	8	
6.1	Screening	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization-defined personnel screening criteria.	5	
6.2	Terms and conditions of employment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	10	
6.2	Terms and conditions of employment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	8	
6.2	Terms and conditions of employment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Social Media & Social Networking Restrictions	HRS-05.2	Mechanisms exist to define rules of behavior that contain explicit restrictions on the use of social media and networking sites, posting information on commercial websites and sharing account information.	5	
6.2	Terms and conditions of employment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	5	
6.2	Terms and conditions of employment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Use of Mobile Devices	HRS-05.5	Mechanisms exist to manage business risks associated with permitting mobile device access to organizational resources.	5	
6.3	Information security awareness, education and training	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	
6.3	Information security awareness, education and training	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	8	
6.3	Information security awareness, education and training	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8	
6.3(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Sensitive / Regulated Data Storage, Handling & Processing	SAT-03.3	Mechanisms exist to ensure that every user accessing a system processing, storing or transmitting sensitive and/or regulated data is formally trained in data handling requirements.	8	
6.3(b)	Other information for public cloud PII protection	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	8	
6.4	Disciplinary process	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Personnel Sanctions	HRS-07	Mechanisms exist to sanction personnel failing to comply with established security policies, standards and procedures.	10	
6.4	Disciplinary process	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Workplace Investigations	HRS-07.1	Mechanisms exist to conduct employee misconduct investigations when there is reasonable assurance that a policy has been violated.	8	
6.5	Responsibilities after termination or change of employment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Personnel Transfer	HRS-08	Mechanisms exist to adjust logical and physical access authorizations to Technology Assets, Applications and/or Services (TAAS) and facilities upon personnel reassignment or transfer, in a timely manner.	5	
6.5	Responsibilities after termination or change of employment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	5	
6.5	Responsibilities after termination or change of employment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Post-Employment Requirements Notification	HRS-09.3	Mechanisms exist to govern former employee behavior by formally notifying terminated individuals of their applicable, legally binding post-employment requirements for the protection of sensitive and/or regulated data.	5	
6.6	Confidentiality or non-disclosure agreements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	8	
6.6	Confidentiality or non-disclosure agreements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	8	
6.7	Remote working	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Remote Access	NET-14	Mechanisms exist to define, control and review organization-approved, secure remote access methods.	8	
6.7	Remote working	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	8	
6.8	Information security event reporting	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5	
6.8	Information security event reporting	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Central Review & Analysis	MON-02.2	Automated mechanisms exist to centrally collect, review and analyze audit records from multiple sources.	5	
6.8	Information security event reporting	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Monitoring Reporting	MON-06	Mechanisms exist to provide an event log report generation capability to aid in detecting and assessing anomalous activities.	8	
6.8	Information security event reporting	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5	
6.8	Information security event reporting	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
7	Physical controls	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
7.1	Physical security perimeters	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
7.1	Physical security perimeters	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	8	
7.1	Physical security perimeters	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	8	
7.1	Physical security perimeters	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Controlled Ingress & Egress Points	PES-03.1	Physical access control mechanisms exist to limit and monitor physical access through controlled ingress and egress points.	8	
7.1	Physical security perimeters	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	8	
7.2	Physical entry	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Controlled Ingress & Egress Points	PES-03.1	Physical access control mechanisms exist to limit and monitor physical access through controlled ingress and egress points.	5	
7.2	Physical entry	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Access Logs	PES-03.3	Physical access control mechanisms generate a log entry for each access attempt through controlled ingress and egress points.	5	
7.2	Physical entry	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	
7.2	Physical entry	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Visitor Control	PES-06	Physical access control mechanisms exist to identify, authorize and monitor visitors before allowing access to the facility (other than areas designated as publicly accessible).	5	
7.2	Physical entry	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	
7.3	Securing offices, rooms and facilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	8	
7.3	Securing offices, rooms and facilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	8	
7.3	Securing offices, rooms and facilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	
7.4	Physical security monitoring	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	
7.4	Physical security monitoring	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Monitoring Physical Alarms	PES-05	Physical access control mechanisms exist to monitor for, detect and respond to physical security incidents.	8	
7.4	Physical security monitoring	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Intrusion Alarms / Surveillance Equipment	PES-05.1	Physical access control mechanisms exist to monitor physical intrusion alarms and surveillance equipment.	8	
7.4	Physical security monitoring	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Monitoring Physical Access To Critical Systems	PES-05.2	Facility security mechanisms exist to monitor physical access to critical systems or sensitive and/or regulated data, in addition to the physical access monitoring of the facility.	8	
7.5	Protecting against physical and environmental threats	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10	
7.5	Protecting against physical and environmental threats	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	8	
7.5	Protecting against physical and environmental threats	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	8	
7.5	Protecting against physical and environmental threats	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with the organization's risk management framework.	8	
7.5	Protecting against physical and environmental threats	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	8	
7.6	Working in secure areas	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	10	
7.7	Clear desk and clear screen	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	
7.7	Clear desk and clear screen	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Endpoint Device Management (EDM)	END-01	Mechanisms exist to facilitate the implementation of Endpoint Device Management (EDM) controls.	5	
7.7	Clear desk and clear screen	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	
7.8	Equipment siting and protection	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	10	
7.9	Security of assets off-premises	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	5	
7.9	Security of assets off-premises	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security of Assets & Media	AST-05	Mechanisms exist to maintain strict control over technology assets, Applications, Services and/or Data (TAASD) to preserve confidentiality.	5	
7.9	Security of assets off-premises	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	
7.9	Security of assets off-premises	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Tampering Detection	AST-08	Mechanisms exist to periodically inspect systems and system components for indicators of compromise (IoC).	5	
7.9	Security of assets off-premises	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Logical Tampering Protection	AST-15	Mechanisms exist to assess the integrity of critical Technology Assets, Applications and/or Services (TAAS) to detect evidence of tampering, where: (1) Logical assessments evaluate the integrity of critical components (e.g., configuration settings); and (2) Physical assessments evaluate assets for evidence of unauthorized access and/or modifications.	5	
7.9	Security of assets off-premises	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Removal of Assets	AST-11	Mechanisms exist to authorize, control and track technology assets entering and exiting organizational facilities.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Use of Personal Devices	AST-12	Mechanisms exist to restrict the possession and/or use of personally-owned Technology Assets, Applications and/or Services (TAAS) within organization-controlled facilities.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media Access	DCH-03	Mechanisms exist to control and restrict access to digital and non-digital media to authorized individuals.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media Storage	DCH-06	Mechanisms exist to: (1) Physically control and securely store digital and non-digital media within controlled areas using organization-defined security measures; and (2) Protect system media until the media are destroyed or sanitized using approved equipment, techniques and procedures.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **ISO/IEC 27018:2025 - Information security, cybersecurity and privacy protection - Guidelines for protection of personally identifiable**

Focal Document URL: <https://www.iso.org/standard/27018>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-iso-27018-2025.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Encrypting Data In Storage Media	DCH-07.2	Cryptographic mechanisms exist to protect the confidentiality and integrity of information stored on digital media during transport outside of controlled areas.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Media Disposal	DCH-08	Mechanisms exist to securely dispose of media when it is no longer required, using formal procedures.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media Use	DCH-10	Mechanisms exist to restrict the use of types of digital media on systems or system components.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Limitations on Use	DCH-10.1	Mechanisms exist to restrict the use and distribution of sensitive and/or regulated data.	5	
7.10	Storage media	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Removable Media Security	DCH-12	Mechanisms exist to restrict removable media in accordance with data handling and acceptable usage parameters.	5	
7.11	Supporting utilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supporting Utilities	PES-07	Facility security mechanisms exist to protect power equipment and power cabling for the system from damage and destruction.	8	
7.11	Supporting utilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Automatic Voltage Controls	PES-07.1	Facility security mechanisms exist to utilize automatic voltage controls for critical system components.	5	
7.11	Supporting utilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Emergency Shutoff	PES-07.2	Facility security mechanisms exist to shut off power in emergency situations by: (1) Placing emergency shutoff switches or devices in close proximity to systems or system components to facilitate safe and easy access for personnel; and (2) Protecting emergency power shutoff capability from unauthorized activation.	5	
7.11	Supporting utilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Emergency Power	PES-07.3	Facility security mechanisms exist to supply alternate power, capable of maintaining minimally-required operational capability, in the event of an extended loss of the primary power source.	5	
7.11	Supporting utilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Emergency Lighting	PES-07.4	Facility security mechanisms exist to utilize and maintain automatic emergency lighting that activates in the event of a power outage or disruption and that covers emergency exits and evacuation routes within the facility.	5	
7.12	Cabling security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supporting Utilities	PES-07	Facility security mechanisms exist to protect power equipment and power cabling for the system from damage and destruction.	8	
7.12	Cabling security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	
7.12	Cabling security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Transmission Medium Security	PES-12.1	Physical security mechanisms exist to protect power and telecommunications cabling carrying data or supporting information services from interception, interference or damage.	8	
7.13	Equipment maintenance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance controls across the enterprise.	10	
7.13	Equipment maintenance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Controlled Maintenance	MNT-02	Mechanisms exist to conduct controlled maintenance activities throughout the lifecycle of the Technology Asset, Application and/or Service (TAAS).	8	
7.13	Equipment maintenance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Timely Maintenance	MNT-03	Mechanisms exist to obtain maintenance support and/or spare parts for Technology Assets, Applications and/or Services (TAAS) within a defined Recovery Time Objective (RTO).	8	
7.14	Secure disposal or re-use of equipment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	10	
7.14(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	8	
8	Technological controls	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	No Relationship	N/A	N/A	N/A	0	
8.1	User endpoint devices	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	
8.1	User endpoint devices	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Kiosks & Point of Interaction (PoI) Devices	AST-07	Mechanisms exist to appropriately protect devices that capture sensitive and/or regulated data via direct physical interaction from tampering and substitution.	5	
8.1	User endpoint devices	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Use of Personal Devices	AST-12	Mechanisms exist to restrict the possession and/or use of personally-owned Technology Assets, Applications and/or Services (TAAS) within organization-controlled facilities.	5	
8.1	User endpoint devices	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Endpoint Device Management (EDM)	END-01	Mechanisms exist to facilitate the implementation of Endpoint Device Management (EDM) controls.	8	
8.1	User endpoint devices	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	
8.1	User endpoint devices	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Account Lockout	IAC-22	Mechanisms exist to enforce a limit for consecutive invalid login attempts by a user during an organization-defined time period and automatically locks the account when the maximum number of unsuccessful attempts is exceeded.	5	
8.1	User endpoint devices	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Centralized Management Of Mobile Devices	MDM-01	Mechanisms exist to implement and govern Mobile Device Management (MDM) controls.	8	
8.1	User endpoint devices	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Access Control For Mobile Devices	MDM-02	Mechanisms exist to enforce access control requirements for the connection of mobile devices to organizational Technology Assets, Applications and/or Services (TAAS).	5	
8.1	User endpoint devices	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Remote Purging	MDM-05	Mechanisms exist to remotely purge selected information from mobile devices.	5	
8.2	Privileged access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Privileged Account Inventories	IAC-16.1	Mechanisms exist to inventory all privileged accounts and validate that each person with elevated privileges is authorized by the appropriate level of organizational management.	8	
8.2	Privileged access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	8	
8.2	Privileged access rights	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Management Approval For Privileged Accounts	IAC-21.3	Mechanisms exist to restrict the assignment of privileged accounts to management-approved personnel and/or roles.	8	
8.3	Information access restriction	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	8	
8.3	Information access restriction	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	8	
8.3	Information access restriction	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Flow Enforcement - Access Control Lists	NET-04	Mechanisms exist to implement and govern Access Control Lists (ACLs) to provide data flow enforcement that explicitly restrict network traffic to only what is authorized.	5	
8.4	Access to source code	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	10	
8.5	Secure authentication	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	
8.5	Secure authentication	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Endpoint Device Management (EDM)	END-01	Mechanisms exist to facilitate the implementation of Endpoint Device Management (EDM) controls.	5	
8.5	Secure authentication	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	
8.5	Secure authentication	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Trusted Path	END-09	Mechanisms exist to establish a trusted communications path between the user and the security functions of the operating system.	5	
8.5	Secure authentication	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Log-On Procedures	SEA-17	Mechanisms exist to utilize a trusted communications path between the user and the security functions of the system.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.5(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	5	
8.6	Capacity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	
8.6	Capacity management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Capacity Planning	CAP-03	Mechanisms exist to conduct capacity planning so that necessary capacity for information processing, telecommunications and environmental support will exist during contingency operations.	8	
8.7	Protection against malware	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize anti-malware technologies to detect and eradicate malicious code.	8	
8.7	Protection against malware	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Automatic Antimalware Signature Updates	END-04.1	Automated mechanisms exist to update anti-malware technologies, including signature definitions.	8	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Periodic Review	CFG-03.1	Mechanisms exist to periodically review system configurations to identify and disable unnecessary and/or non-secure functions, ports, protocols and services.	5	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Vulnerabilities Related To Incidents	IRO-10.3	Mechanisms exist to report system vulnerabilities associated with reported cybersecurity and data protection incidents to organization-defined personnel or roles.	5	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Personal Data (PD) Control Testing, Training & Monitoring	PRI-08	Mechanisms exist to conduct testing, training and monitoring activities for Personal Data (PD) controls.	5	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Attack Surface Scope	VPM-01.1	Mechanisms exist to define and manage the scope for its attack surface management activities.	5	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	5	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Vulnerability Ranking	VPM-03	Mechanisms exist to identify and assign a risk ranking to newly discovered security vulnerabilities using reputable outside sources for security vulnerability information.	5	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	5	
8.8	Management of technical vulnerabilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	5	
8.9	Configuration management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Configuration Management Database (CMDB)	AST-02.9	Mechanisms exist to implement and manage a Configuration Management Database (CMDB), or similar technology, to monitor and govern technology asset-specific information.	8	
8.9	Configuration management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Configuration Management Program	CFG-01	Mechanisms exist to facilitate the implementation of configuration management controls.	10	
8.9	Configuration management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Assignment of Responsibility	CFG-01.1	Mechanisms exist to implement a segregation of duties for configuration management that prevents developers from performing production configuration management duties.	5	
8.9	Configuration management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8	
8.9	Configuration management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Reviews & Updates	CFG-02.1	Mechanisms exist to review and update baseline configurations: (1) At least annually; (2) When required due to so; or (3) As part of system component installations and upgrades.	8	
8.9	Configuration management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	8	
8.10	Information deletion	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	8	
8.10	Information deletion	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Physical Media Disposal	DCH-08	Mechanisms exist to securely dispose of media when it is no longer required, using formal procedures.	8	
8.10	Information deletion	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	System Media Sanitization	DCH-09	Mechanisms exist to sanitize system media with the strength and integrity commensurate with the classification or sensitivity of the information prior to disposal, release out of organizational control or release for reuse.	8	
8.10	Information deletion	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	System Media Sanitization Documentation	DCH-09.1	Mechanisms exist to supervise, track, document and verify system media sanitization and disposal actions.	5	
8.10	Information deletion	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Sanitization of Personal Data (PD)	DCH-09.3	Mechanisms exist to facilitate the sanitization of Personal Data (PD).	5	
8.10	Information deletion	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	8	
8.10	Information deletion	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Information Disposal	DCH-21	Mechanisms exist to securely dispose of, destroy or erase information.	8	
8.10	Information deletion	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and (3) Use organization-defined techniques or methods to ensure secure deletion or destruction of PD (including originals, copies and archived records).	5	
8.11	Data masking	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Masking Displayed Data	DCH-03.2	Mechanisms exist to apply data masking to sensitive and/or regulated information that is displayed or printed.	8	
8.11	Data masking	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Removal, Masking, Encryption, Hashing or Replacement of Direct Identifiers	DCH-23.4	Mechanisms exist to remove, mask, encrypt, hash or replace direct identifiers in a dataset.	5	
8.11	Data masking	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Anonymization	PRI-05.3	Mechanisms exist to mask sensitive and/or regulated data through data anonymization, pseudonymization, redaction and/or de-identification.	8	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Configuration Management Program	CFG-01	Mechanisms exist to facilitate the implementation of configuration management controls.	8	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS) for High-Risk Areas	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	8	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	8	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	8	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **ISO/IEC 27018:2025 - Information security, cybersecurity and privacy protection - Guidelines for protection of personally identifiable**

Focal Document URL: <https://www.iso.org/standard/27018>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-iso-27018-2025.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	8	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	8	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Prevent Discovery of Internal Information	NET-03.3	Mechanisms exist to prevent the public disclosure of internal network information.	5	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Prevent Unauthorized Exfiltration	NET-03.5	Automated mechanisms exist to prevent the unauthorized exfiltration of sensitive and/or regulated data across managed interfaces.	5	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Information Leakage Due To Electromagnetic Signals Emanations	PES-13	Facility security mechanisms exist to protect the system from information leakage due to electromagnetic signals emanations.	5	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	8	
8.12	Data leakage prevention	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Centralized Management of Security, Compliance & Resilience Controls	SEA-01.1	Mechanisms exist to centrally-manage the organization-wide management and implementation of security, compliance and resilience controls and related processes.	8	
8.13	Information backup	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	8	
8.13	Information backup	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Testing for Reliability & Integrity	BCD-11.1	Mechanisms exist to routinely test backups that verify the reliability of the backup process, as well as the integrity and availability of the data.	8	
8.13	Information backup	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Separate Storage for Critical Information	BCD-11.2	Mechanisms exist to store backup copies of critical software and other security-related information in a separate facility or in a fire-rated container that is not collocated with the system being backed up.	8	
8.13	Information backup	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Cryptographic Protection	BCD-11.4	Cryptographic mechanisms exist to prevent the unauthorized disclosure and/or modification of backup information.	8	
8.13(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
8.14	Redundancy of information processing facilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Alternate Storage Site	BCD-08	Mechanisms exist to establish an alternate storage site that includes both the assets and necessary agreements to permit the storage and recovery of system backup information.	8	
8.14	Redundancy of information processing facilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Alternate Processing Site	BCD-09	Mechanisms exist to establish an alternate processing site that provides security measures equivalent to that of the primary site.	8	
8.14	Redundancy of information processing facilities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Redundant Secondary System	BCD-11.7	Mechanisms exist to maintain a failover capability, which is not collocated with the primary Technology Asset, Application and/or Service (TAAS), which can be activated with little-to-no loss of information or disruption to operations.	8	
8.15	Logging	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	
8.15	Logging	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and supply chain activities to achieve integrated situational awareness.	8	
8.15	Logging	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	8	
8.15	Logging	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Correlate Monitoring Information	MON-02.1	Automated mechanisms exist to correlate both technical and non-technical information from across the enterprise by a Security Incident Event Manager (SIEM) or similar automated tool, to enhance organization-wide situational awareness.	8	
8.15	Logging	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Central Review & Analysis	MON-02.2	Automated mechanisms exist to centrally collect, review and analyze audit records from multiple sources.	8	
8.15	Logging	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	8	
8.15	Logging	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Privileged Functions Logging	MON-03.3	Mechanisms exist to log and review the actions of users and/or services with elevated privileges.	5	
8.15	Logging	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Monitoring Reporting	MON-06	Mechanisms exist to provide an event log report generation capability to aid in detecting and assessing anomalous activities.	8	
8.15	Logging	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	8	
8.15(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	8	
8.16	Monitoring activities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	5	
8.16	Monitoring activities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Intrusion Detection & Prevention Systems (IDS & IPS)	MON-01.1	Mechanisms exist to implement Intrusion Detection / Prevention Systems (IDS / IPS) technologies on critical systems, key network segments and network choke points.	5	
8.16	Monitoring activities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Automated Tools for Real-Time Analysis	MON-01.2	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support near real-time analysis and incident escalation.	5	
8.16	Monitoring activities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Inbound & Outbound Communications Traffic	MON-01.3	Mechanisms exist to continuously monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.	5	
8.16	Monitoring activities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	
8.16	Monitoring activities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Central Review & Analysis	MON-02.2	Automated mechanisms exist to centrally collect, review and analyze audit records from multiple sources.	5	
8.17	Clock synchronization	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Clock Synchronization	SEA-20	Mechanisms exist to utilize time-synchronization technology to synchronize all critical system clocks.	10	
8.18	Use of privileged utility programs	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	10	
8.19	Installation of software on operational systems	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10	
8.19	Installation of software on operational systems	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	8	
8.19	Installation of software on operational systems	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	8	
8.19	Installation of software on operational systems	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Prohibit Installation Without Privileged Status	END-03	Automated mechanisms exist to prohibit software installations without explicitly assigned privileged status.	8	
8.19	Installation of software on operational systems	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Governing Access Restriction for Change	END-03.2	Mechanisms exist to define, document, approve and enforce access restrictions associated with changes to Technology Assets, Applications and/or Services (TAAS).	8	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **ISO/IEC 27018:2025 - Information security, cybersecurity and privacy protection - Guidelines for protection of personally identifiable**

Focal Document URL: <https://www.iso.org/standard/27018>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-iso-27018-2025.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.20	Networks security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Network Diagrams & Data Flow Diagrams (DFDs)	AST-04	Mechanisms exist to maintain network architecture diagrams that: (1) Contain sufficient detail to assess the security of the network's architecture; (2) Reflect the current architecture of the network environment; and (3) Document all sensitive and/or regulated data flows.	5	
8.20	Networks security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	
8.20	Networks security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Layered Network Defenses	NET-02	Mechanisms exist to implement security functions as a layered structure that minimizes interactions between layers of the design and avoids any dependence by lower layers on the functionality or correctness of higher layers.	8	
8.20	Networks security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Boundary Protection	NET-03	Mechanisms exist to monitor and control communications at the external network boundary and at key internal boundaries within the network.	8	
8.20	Networks security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Flow Enforcement – Access Control Lists (ACLs)	NET-04	Mechanisms exist to implement and govern Access Control Lists (ACLs) to provide data flow enforcement that explicitly restrict network traffic to only what is authorized.	8	
8.20	Networks security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Deny Traffic by Default & Allow Traffic by Exception	NET-04.1	Mechanisms exist to configure firewall and router configurations to deny network traffic by default and allow network traffic by exception (e.g., deny all, permit by exception).	8	
8.20	Networks security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	8	
8.20	Networks security	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	DMZ Networks	NET-08.1	Mechanisms exist to monitor De-Militarized Zone (DMZ) network segments to separate untrusted networks from trusted networks.	5	
8.21	Security of network services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	
8.21	Security of network services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Boundary Protection	NET-03	Mechanisms exist to monitor and control communications at the external network boundary and at key internal boundaries within the network.	8	
8.21	Security of network services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Network Intrusion Detection / Prevention Systems (NIDS / NIPS)	NET-08	Mechanisms exist to employ Network Intrusion Detection / Prevention Systems (NIDS/NIPS) to detect and/or prevent intrusions into the network.	5	
8.21	Security of network services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Wireless Networking	NET-15	Mechanisms exist to control authorized wireless usage and monitor for unauthorized wireless access.	8	
8.21	Security of network services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
8.21	Security of network services	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	5	
8.22	Segregation of networks	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	8	
8.22	Segregation of networks	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security Management Subnets	NET-06.1	Mechanisms exist to implement security management subnets to isolate security tools and support components from other internal system components by implementing separate subnetworks with managed interfaces to other components of the system.	5	
8.22	Segregation of networks	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Use of Demilitarized Zones (DMZ)	WEB-02	Mechanisms exist to utilize a Demilitarized Zone (DMZ) to restrict inbound traffic to authorized Technology Assets, Applications and/or Services (TAAS) on certain services, protocols and ports.	5	
8.23	Web filtering	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	DNS & Content Filtering	NET-18	Mechanisms exist to force Internet-bound network traffic through a proxy device (e.g., Policy Enforcement Point (PEP)) for URL content filtering and DNS filtering to limit a user's ability to connect to dangerous or prohibited Internet sites.	10	
8.24	Use of cryptography	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	
8.24	Use of cryptography	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Transmission Confidentiality	CRY-03	Cryptographic mechanisms exist to protect the confidentiality of data being transmitted.	8	
8.24	Use of cryptography	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Transmission Integrity	CRY-04	Cryptographic mechanisms exist to protect the integrity of data being transmitted.	8	
8.24	Use of cryptography	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Encrypting Data At Rest	CRY-05	Cryptographic mechanisms exist to prevent unauthorized disclosure of data at rest.	8	
8.24	Use of cryptography	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	8	
8.24	Use of cryptography	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Cryptographic Key Loss or Change	CRY-09.3	Mechanisms exist to ensure the availability of information in the event of the loss of cryptographic keys by individual users.	5	
8.24	Use of cryptography	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Control & Distribution of Cryptographic Keys	CRY-09.4	Mechanisms exist to facilitate the secure distribution of symmetric and asymmetric cryptographic keys using industry recognized key management technology and processes.	5	
8.24(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	8	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Development & Test Environment Configurations	CFG-02.4	Mechanisms exist to manage baseline configurations for development and test environments separately from operational baseline configurations to minimize the risk of unintentional changes.	5	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Threat Analysis & Flaw Remediation During Development	IAO-04	Mechanisms exist to require system developers and integrators to create and execute a Security Testing and Evaluation (ST&E) plan, or similar process, to identify and remediate flaws during development.	5	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	8	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	8	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Development Methods, Techniques & Processes	TDA-02.3	Mechanisms exist to require software developers to ensure that their software development processes employ industry-recognized secure practices for secure programming, engineering methods, quality control processes and validation techniques to minimize flawed and/or malformed software.	5	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	5	
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.25	Secure development lifecycle	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	
8.26	Application security requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Application Programming Interface (API) Security	CLD-04	Mechanisms exist to ensure support for secure interoperability between components with Application Programming Interfaces (APIs).	5	
8.26	Application security requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	
8.26	Application security requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	5	
8.26	Application security requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Transmission Confidentiality	CRY-03	Cryptographic mechanisms exist to protect the confidentiality of data being transmitted.	5	
8.26	Application security requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Transmission Integrity	CRY-04	Cryptographic mechanisms exist to protect the integrity of data being transmitted.	5	
8.26	Application security requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to protectively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and	5	
8.26	Application security requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	8	
8.26	Application security requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	5	
8.26	Application security requirements	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	8	
8.27	Secure system architecture and engineering principles	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Periodic Review	CFG-03.1	Mechanisms exist to periodically review system configurations to identify and disable unnecessary and/or non-secure functions, ports, protocols and services.	5	
8.27	Secure system architecture and engineering principles	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	8	
8.27	Secure system architecture and engineering principles	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Developer Architecture & Design	TDA-05	Mechanisms exist to require the developers of Technology Assets, Applications and/or Services (TAAS) to produce a design specification and security architecture that: (1) Is consistent with and supportive of the organization's security architecture which is established within and is an integrated part of the organization's enterprise architecture; (2) Accurately and completely describes the required security functionality and the allocation of security, compliance and resilience controls among physical and logical components; and (3) Expresses how individual security functions, mechanisms and services work together to provide required security capabilities and a unified approach to protection.	8	
8.27	Secure system architecture and engineering principles	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	8	
8.28	Secure coding	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	10	
8.29	Security testing in development and acceptance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	8	
8.29	Security testing in development and acceptance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Specialized Assessments	IAO-02.2	Mechanisms exist to conduct specialized assessments for: (1) Statutory, regulatory and contractual compliance obligations; (2) Monitoring capabilities; (3) Mobile devices; (4) Databases; (5) Application security; (6) Embedded technologies (e.g., IoT, OT, etc.); (7) Vulnerability management; (8) Malicious code; (9) Insider threats; (10) Performance/load testing; (11) Artificial Intelligence and Autonomous Technologies (AAT); and/or (12) Other controls that are not covered by the SCF or other standards.	5	
8.29	Security testing in development and acceptance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	
8.29	Security testing in development and acceptance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Development Methods, Techniques & Processes	TDA-02.3	Mechanisms exist to require software developers to ensure that their software development processes employ industry-recognized secure practices for secure programming, engineering methods, quality control processes and validation techniques to minimize flawed and/or malformed software.	8	
8.29	Security testing in development and acceptance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Criticality Analysis During Development	TDA-06.1	Mechanisms exist to require the developer of the Technology Asset, Application and/or Service (TAAS) to perform a criticality analysis at organization-defined decision points in the Secure Development Life Cycle (SDLC).	8	
8.29	Security testing in development and acceptance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	10	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	8	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supply Chain Risk Assessment	RSK-09.1	Mechanisms exist to periodically assess supply chain risks associated with Technology Assets, Applications and/or Services (TAAS).	8	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Developer Architecture & Design	TDA-05	Mechanisms exist to require the developers of Technology Assets, Applications and/or Services (TAAS) to produce a design specification and security architecture that: (1) Is consistent with and supportive of the organization's security architecture which is established within and is an integrated part of the organization's enterprise architecture; (2) Accurately and completely describes the required security functionality and the allocation of security, compliance and resilience controls among physical and logical components; and (3) Expresses how individual security functions, mechanisms and services work together to provide required security capabilities and a unified approach to protection.	5	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	8	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	8	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Developer Configuration Management	TDA-14	Mechanisms exist to require system developers and integrators to perform configuration management during system design, development, implementation and operation.	5	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries	5	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	8	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Supply Chain Risk Management (SCRM)	TPM-03	Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS) supply chains; and (2) Take appropriate remediation actions to minimize the organization's exposure to those risks and threats, as necessary.	8	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	8	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	8	
8.30	Outsourced development	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Third-Party Personnel Security	TPM-06	Mechanisms exist to control personnel security requirements including security roles and responsibilities for third-party providers.	8	
8.31	Separation of development, test and production environments	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	5	
8.31	Separation of development, test and production environments	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	
8.31(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	5	
8.31(a)	Public cloud PII protection implementation guidance	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	8	
8.32	Change management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10	
8.32	Change management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	8	
8.32	Change management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	8	
8.32	Change management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	5	
8.32	Change management	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Developer Configuration Management	TDA-14	Mechanisms exist to require system developers and integrators to perform configuration management during system design, development, implementation and operation.	5	
8.33	Test information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	De-identification (Anonymization)	DCH-23	Mechanisms exist to anonymize data by removing Personal Data (PD) from datasets.	5	
8.33	Test information	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Intersects With	Use of Live Data	TDA-10	Mechanisms exist to approve, document and control the use of live data in development and test environments.	8	
8.34	Protection of information systems during audit testing	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/27018	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	